SIMATS ENGINEERING

CSA6303- Threat Intelligence and Network Security

A1-Threat Intelligence Report

Assessment Questions

Subject	Threat Intelligence	**Total Marks**	50
Questions	10 (all compulsory)	**Marks per Question**	5
REg.No	192465054	**Name**	A Abhinava Reddy
Faculty	Dr.V.Parthipan	**Slot**	A

Instructions: Answer all questions. Each question carries 5 marks. Support answers with examples and diagrams where appropriate.

Code of Conduct:

I A.Abhinava Reddy,192465054(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of Student

A Abhinava Reddy

CSA6303 – Threat Intelligence and Network Security

Answers to Questions 1 – 10 (5 Marks Each)

Q1. Malware [5 Marks]

Definition: Malware (malicious software) is any program or code deliberately created to damage, disrupt, steal data from, or gain unauthorised access to a computer, network or user, without the owner's knowledge or consent.

Types of malware

Type	How it spreads	Key behaviour	Impact on victim
Virus	Attaches itself to executable files or documents; spreads when an infected file is run, copied or shared (USB, email attachments).	Needs a host file and user action to activate.	Corrupts or deletes files and slows the system.
Worm	Self-replicates over networks by exploiting vulnerabilities, email or shared drives, with no user action needed.	Standalone and self-propagating.	Consumes bandwidth and resources, causing network congestion or outage.
Trojan	Disguised as legitimate software (cracked apps, fake installers, malicious downloads); the user installs it willingly.	Does not replicate; opens a backdoor or drops other malware.	Attacker gains remote control or steals credentials.
Ransomware	Phishing emails, malicious downloads, exposed RDP and unpatched vulnerabilities.	Encrypts files and demands payment for the key.	Loss of access to data and financial loss from ransom and downtime.
Spyware	Bundled with free software, malicious websites or phishing links.	Secretly monitors activity, keystrokes and browsing.	Theft of passwords and personal or banking data, and loss of privacy.

Note: the question asks for any four; the table covers five for completeness (virus, worm, trojan and ransomware are sufficient for full marks).

Q2. Phishing [5 Marks]

How a phishing attack is carried out: Phishing is a social-engineering attack in which the attacker impersonates a trusted entity to trick victims into revealing sensitive information or installing malware. Typical stages:

1. Reconnaissance: the attacker selects targets and gathers details such as email addresses and organisation names.
2. Preparation: a fake email, SMS or website is built that imitates a bank, company or colleague, using a spoofed sender and cloned login page.
3. Delivery: the message is sent, creating urgency ("account suspended", "verify now").

4. Deception: the victim clicks a malicious link or attachment and enters credentials on the fake page, or downloads malware.
5. Exploitation: the attacker harvests credentials or gains access, then commits fraud, data theft or lateral movement.

Spear phishing vs whaling vs vishing

Aspect	Spear phishing	Whaling	Vishing
Target	A specific individual or small group.	Senior executives (CEO, CFO, directors).	Any victim, via voice calls.
Medium	Personalised email or message.	Highly polished email or document, often appearing legal or financial.	Phone call or voicemail (voice phishing).
Method	Uses researched personal details to appear genuine.	Impersonates authority, e.g. urgent wire transfer or legal notice.	Caller poses as bank, tech support or government, pressing for OTP or PIN.

Three measures to reduce phishing risk

- **Security awareness training and simulated phishing exercises** so employees can recognise and report suspicious messages.
- **Email filtering and authentication** (SPF, DKIM, DMARC, spam and link scanning) to block spoofed or malicious mail.
- **Multi-factor authentication (MFA) and a reporting process** so stolen passwords alone cannot give access.

Q3. DoS and DDoS [5 Marks]

Aspect	DoS	DDoS
Source	Single machine or connection.	Many compromised machines (a botnet) at once.
Scale	Limited traffic volume.	Very large, can reach hundreds of Gbps.
Detection / blocking	Easy to trace and block by filtering one IP.	Hard, as traffic comes from thousands of IPs.
Attacker identity	Easier to trace.	Difficult to trace, since bots are innocent hijacked devices.

Working of a SYN flood: A SYN flood exploits the TCP three-way handshake (SYN → SYN-ACK → ACK).

- The attacker sends a large number of SYN packets, usually with spoofed source IP addresses.
- The server replies with SYN-ACK and allocates a half-open connection entry in its backlog queue, waiting for the final ACK.
- The ACK never arrives because the spoofed addresses do not respond, so the half-open entries stay until they time out.
- The backlog queue fills up and the server can no longer accept legitimate connection requests, resulting in denial of service.

Two mitigation techniques

- **SYN cookies:** the server encodes connection state in the SYN-ACK sequence number instead of storing it, so no memory is used until a valid ACK returns.
- **Rate limiting and firewall/IPS filtering:** limit SYN packets per source, shorten the SYN timeout and increase the backlog size; use upstream DDoS scrubbing or a CDN for large attacks.

Q4. Man-in-the-Middle Attacks [5 Marks]

Definition: A Man-in-the-Middle (MITM) attack occurs when an attacker secretly positions themselves between two communicating parties, intercepting and possibly altering messages while both believe they are talking directly to each other.

Two techniques

- **ARP poisoning:** the attacker sends forged ARP replies on the LAN, associating their MAC address with the IP of the gateway (and the victim). Traffic from the victim now flows through the attacker's machine, which can read or modify it before forwarding.
- **Rogue Wi-Fi access point (evil twin):** the attacker sets up a hotspot with a familiar name (e.g. "Free_Airport_WiFi"). Victims who connect have all their traffic routed through the attacker, who can capture credentials and sessions.
- **SSL stripping (additional example):** the attacker downgrades an HTTPS connection to HTTP so the victim's traffic is sent in plaintext.

How encryption helps

- TLS/HTTPS encrypts data in transit, so an intercepted payload is unreadable without the session key (confidentiality).
- Digital certificates authenticate the server, so a fake site or rogue AP fails certificate validation.
- Message authentication codes ensure integrity, so tampering is detected.
- HSTS, VPNs and end-to-end encryption add further protection against stripping and rogue networks.

Q5. Spoofing and Sniffing [5 Marks]

Aspect	Spoofing	Sniffing
Nature	Active attack: forging identity (IP, MAC, email) to impersonate a trusted source.	Passive attack: capturing and inspecting network traffic.
Goal	Gain access, bypass filters, redirect traffic or hide identity.	Eavesdrop on data such as credentials and messages.
Effect on traffic	Injects false packets or identities.	Does not alter traffic; hard to detect.
Threat to	Authentication and integrity.	Confidentiality.

IP spoofing: the attacker forges the source IP address in packet headers. Example: in a SYN flood or reflection/amplification DDoS attack, packets carry the victim's IP as source, so replies flood the victim while the attacker stays hidden. It can also bypass IP-based access control lists.

ARP spoofing: the attacker sends fake ARP messages to map their MAC address to a legitimate IP. Example: on a shared LAN the attacker claims to be the default gateway; all hosts send traffic to the attacker (enabling MITM or sniffing) before it is forwarded onward.

Packet sniffers such as Wireshark

- **Malicious use:** capturing unencrypted credentials (HTTP, FTP, Telnet), session cookies and private data on open or shared networks.
- **Legitimate use:** network troubleshooting, performance analysis, protocol debugging, detecting intrusions or malware traffic, forensic investigation and teaching.

Q6. Vulnerability Assessment [5 Marks]

Definition: Vulnerability assessment (VA) is the systematic process of identifying, classifying and prioritising security weaknesses in systems, networks and applications.

Main phases

1. Planning and scoping: define assets, targets, objectives and rules.
2. Asset discovery: identify hosts, services, open ports and software versions.
3. Vulnerability scanning: use automated tools to detect known weaknesses (missing patches, misconfigurations, weak credentials).
4. Analysis and prioritisation: validate findings, remove false positives and rank by severity and business impact.
5. Reporting: document findings with evidence and recommended fixes.
6. Remediation and re-scan: patch or mitigate, then verify the fixes and repeat periodically.

Vulnerability assessment vs penetration testing

Aspect	Vulnerability assessment	Penetration testing
Goal	Find and list as many weaknesses as possible.	Exploit weaknesses to prove real-world impact.
Approach	Mostly automated scanning.	Manual and tool-assisted, simulating an attacker.
Depth	Broad; does not exploit.	Deep; chains vulnerabilities and attempts compromise.
Frequency	Regular (weekly, monthly).	Periodic (annually or after major changes).
Output	Prioritised list of vulnerabilities.	Proof of exploitation and attack paths.

Common scanning tools: Nessus and OpenVAS (Greenbone); others include Qualys and Nmap (with scripts).

Q7. Vulnerability Scoring [5 Marks]

CVE (Common Vulnerabilities and Exposures): a public, standardised catalogue that assigns a unique identifier (e.g. CVE-2021-44228) to each publicly disclosed vulnerability, so that tools, vendors and teams refer to the same flaw consistently.

CVSS (Common Vulnerability Scoring System): an open framework that rates the severity of a vulnerability on a 0.0 – 10.0 scale. Metric groups are Base (exploitability and impact, e.g. attack vector, complexity, privileges, user interaction, effect on C/I/A), Temporal (exploit maturity, patch availability) and Environmental (organisation-specific context). Ratings: 0.1–3.9 Low, 4.0–6.9 Medium, 7.0–8.9 High, 9.0–10.0 Critical.

How CVSS helps prioritisation

- Gives an objective, comparable severity number so teams can sort thousands of findings.
- Lets critical and high issues be patched first and low issues scheduled later, and supports SLA targets.

Why a high CVSS score alone should not decide patch order

- **Exploitability in the wild:** a medium-score flaw that is actively exploited may be more urgent than a critical one with no known exploit.
- **Asset criticality:** a vulnerability on an internet-facing or business-critical server matters more than on an isolated test machine.
- **Exposure and compensating controls:** firewalls, segmentation or WAF rules may reduce real risk.
- **Patch availability, downtime and cost** also affect scheduling, as does regulatory impact. Risk-based approaches (e.g. combining CVSS with threat intelligence, EPSS or CISA KEV) are therefore preferred.

Q8. Threat Data Sources and OSINT [5 Marks]

Main sources of threat data

Source	Description	Examples
Internal	Data generated within the organisation; highly relevant to its own environment.	Firewall, IDS/IPS, SIEM and DNS logs, endpoint alerts, past incident reports, honeypots.
External	Data obtained from outside parties, including sharing communities.	Government CERTs (CERT-In, US-CERT), ISACs, vendor advisories, peer sharing groups.
Open-source	Freely available public information.	Public blocklists, security blogs, social media, paste sites, MITRE ATT&CK, AlienVault OTX.
Commercial	Paid, curated and enriched intelligence with support and analysis.	Recorded Future, CrowdStrike, Mandiant, Anomali.

Open-Source Intelligence (OSINT): intelligence produced from publicly available information that is collected, analysed and used to support security decisions, such as profiling threat actors, finding exposed assets and tracking emerging threats.

Three OSINT sources / tools

- **Shodan:** a search engine for internet-connected devices; reveals exposed services, open ports and vulnerable systems.
- **Maltego:** a link-analysis tool that maps relationships between domains, IPs, people and infrastructure.

- **VirusTotal / theHarvester:** VirusTotal checks files, URLs and IPs against many antivirus engines and reputation sources; theHarvester gathers emails, subdomains and hosts from public sources. (Others: Google dorking, WHOIS, social media.)

Q9. Indicators of Compromise (IoCs) [5 Marks]

Definition: Indicators of Compromise are pieces of forensic evidence or artefacts observed on a network or system that suggest a security breach has occurred or is under way.

Classification

Category	Description	Examples
Network-based	Observed in network traffic or communications.	Connections to known malicious IPs or domains; unusual outbound traffic or C2 beaconing.
Host-based	Found on an individual endpoint or server.	New unknown processes or services; unauthorised registry or startup changes; unexpected admin accounts.
File-based	Properties of malicious files.	Known malware file hashes (MD5/SHA-256); suspicious file names or paths, and files with altered extensions (e.g. ransomware).

Use of IoCs during incident response

- **Detection:** IoCs are loaded into SIEM, IDS/IPS and EDR tools to raise alerts when a match appears.
- **Scoping and triage:** searching logs and endpoints for the same indicators identifies which systems are affected.
- **Containment and eradication:** block malicious IPs/domains, isolate infected hosts and remove malicious files.
- **Investigation and recovery:** indicators help reconstruct the attack timeline, and are shared with partners to prevent recurrence.

Q10. Threat Feeds [5 Marks]

Definition: A threat intelligence feed is a continuously updated stream of data about current threats, such as malicious IP addresses, domains, URLs, file hashes and attacker tactics, supplied in a machine-readable form so security tools can consume it automatically.

Common feed formats and sharing standards

- **Simple formats:** CSV, JSON, XML and plain-text lists (e.g. blocklists of IPs and domains).
- **STIX (Structured Threat Information eXpression):** a standardised language that describes threat information such as indicators, malware, threat actors and campaigns, and the relationships between them.
- **TAXII (Trusted Automated eXchange of Intelligence Information):** a transport protocol, working over HTTPS, that defines how STIX content is exchanged between systems through collections and channels.
- **Others:** OpenIOC and MISP formats.

Advantages

- Provide real-time, automated updates that improve early detection and blocking.
- Save the cost and effort of collecting data independently, and give wider visibility than internal logs alone.

Limitations

- False positives and stale data can cause alert fatigue and wrongly blocked traffic if indicators are not vetted or aged out.
- **Volume and lack of context:** large raw feeds are hard to operationalise, and may not be relevant to the organisation's own environment; quality varies and commercial feeds cost money.

Example feeds

AlienVault OTX (Open Threat Exchange), abuse.ch (URLhaus, Feodo Tracker), MISP community feeds, and Cisco Talos Intelligence (commercial examples include Recorded Future and CrowdStrike).